

Aula 6 (Módulo 03) — Firewall, Proxy e VPN

1. Firewall — o "porteiro" da rede

Já mencionamos firewall algumas vezes (Módulo 01, Aula 6; Módulo 02, Aula 3) — agora vamos formalizar. Um **firewall** decide, com base em regras, **o que pode passar e o que é bloqueado**, tipicamente observando: IP de origem/destino, porta, protocolo (TCP/UDP), e direção (entrada/saída).

Tipos, do mais simples ao mais sofisticado

- **Filtro de pacotes (stateless)**: avalia cada pacote isoladamente, sem lembrar do contexto da conexão. Simples e rápido, mas mais fácil de contornar.
- **Stateful**: lembra o estado de cada conexão (ex.: "esse pacote é resposta de uma conexão que EU iniciei" → permite; "esse pacote está tentando iniciar uma conexão nova de fora, sem eu ter pedido" → normalmente bloqueia). É o modelo padrão na maioria dos firewalls modernos, incluindo `ufw` / `firewalld` (Linux) e o Windows Firewall que já vimos.
- **Next-Generation Firewall (NGFW)**: além de IP/porta, também inspeciona o **conteúdo** do tráfego (camada de aplicação) — consegue, por exemplo, permitir a porta 443 (HTTPS) em geral, mas bloquear especificamente acesso a certas categorias de site, mesmo todas usando a mesma porta.

Por que importa para segurança: a regra de ouro de firewall é "**negar por padrão, permitir só o necessário**" (*default deny / allowlist*) — o oposto de "permitir tudo e bloquear só o que eu já sei que é ruim" (*default allow / blocklist*), que é mais fraco porque você só se defende de ameaças **já conhecidas**. Praticamente todo ambiente corporativo bem configurado segue o modelo *default deny*.

2. Proxy — o intermediário

Um **proxy** é um servidor que fica **no meio** entre um cliente e o destino, repassando (ou não) a comunicação. Duas direções principais:

- **Forward proxy** (proxy de saída): fica entre os usuários **internos** e a internet. Toda a navegação passa por ele primeiro. Usos comuns: filtrar sites indesejados, registrar (logar) todo tráfego web para auditoria, e até fazer inspeção de conteúdo criptografado (com um certificado próprio da empresa — assunto que vamos aprofundar na próxima aula, sobre TLS).
- **Reverse proxy** (proxy de entrada): fica entre a internet e os **servidores internos** de uma empresa — os visitantes de um site, por exemplo, na verdade conversam com o reverse proxy, que repassa internamente para o servidor real. Usado para balanceamento de carga, esconder a infraestrutura real, e também para filtrar tráfego malicioso antes que ele chegue ao servidor de verdade (um **Web Application Firewall**, ou WAF, normalmente funciona dessa forma — veremos isso com detalhe no Módulo 18, Web Security).

Por que importa para segurança: logs de proxy (forward proxy, especialmente) são uma das fontes de dados mais ricas para um SOC — eles mostram **todo** o tráfego web de saída da organização, incluindo qual usuário/máquina acessou qual site, quando. É uma fonte de detecção poderosa para identificar máquinas comprometidas se comunicando com domínios maliciosos (lembra do C2 e do DNS suspeito, Aula 4?).

3. VPN — estendendo a rede privada com segurança

VPN (*Virtual Private Network*) cria um "túnel" criptografado através de uma rede não confiável (normalmente a internet pública), fazendo o tráfego parecer — e se comportar — como se estivesse dentro de uma rede privada, mesmo estando fisicamente em outro lugar.

Dois usos principais:

- **Acesso remoto:** um funcionário trabalhando de casa se conecta via VPN para acessar recursos internos da empresa como se estivesse no escritório.
- **Site-to-site:** conecta duas redes inteiras (ex.: duas filiais de uma empresa) de forma permanente e criptografada através da internet.

Por que importa para segurança: VPN criptografa o **conteúdo** do tráfego contra observação externa, mas isso também significa que um firewall/proxy tradicional na borda da rede **não consegue inspecionar** o que passa dentro do túnel — por isso, credenciais de VPN comprometidas são um vetor de ataque extremamente valioso (o atacante, uma vez conectado, é tratado como se estivesse "de dentro" da rede confiável). Autenticação forte de VPN (idealmente com múltiplos fatores — MFA, que veremos em detalhe mais adiante) é um dos controles de segurança de maior prioridade em qualquer ambiente que ofereça acesso remoto.

4. Conectando tudo

```
Firewall → decide O QUE pode passar (IP/porta/protocolo, ou conteúdo em NGFW)
Proxy    → decide POR ONDE o tráfego passa, registra e pode inspecionar
           (forward: usuários → internet; reverse: internet → servidores)
VPN      → estende a rede privada com segurança através de rede não confiável,
           mas cria um "ponto cego" para inspeção na borda
```

5. Exercício prático (revisão)

Sem precisar de ferramenta nova, revise o que já vimos no Módulo 01 (Aula 6) e Módulo 02 (Aula 3):

```
sudo ufw status verbose          # Linux
```

```
Get-NetFirewallProfile          # Windows
```

Pergunte-se: o firewall dessa máquina segue o modelo *default deny* (bloqueia tudo por padrão, exceto o explicitamente permitido) ou *default allow*? Isso já revela bastante sobre a postura de segurança daquele ambiente.

6. Recapitulando

- Firewall decide o que passa; a regra de ouro é *default deny*.

- Forward proxy fica entre usuários internos e a internet (logs valiosos para SOC); reverse proxy fica entre a internet e servidores internos (base de WAF).
- VPN estende a rede privada com segurança sobre rede não confiável, mas cria um ponto cego de inspeção — credenciais de VPN comprometidas são um vetor de ataque de alto valor.

Próxima aula (fecha o Módulo 03)

HTTP/HTTPS, TLS, certificados, cookies, sessões e APIs — a camada de aplicação que roda por cima de tudo que vimos até aqui, e que domina a maior parte do tráfego da internet moderna.

Fontes recomendadas

- **NIST SP 800-41 Rev. 1 — "Guidelines on Firewalls and Firewall Policy"**: referência oficial de boas práticas de firewall, incluindo o princípio de *default deny*. <https://csrc.nist.gov/pubs/sp/800/41/r1/final>
- **NIST SP 800-77 Rev. 1 — "Guide to IPsec VPNs"**: referência oficial de VPN e suas considerações de segurança. <https://csrc.nist.gov/pubs/sp/800/77/r1/final>